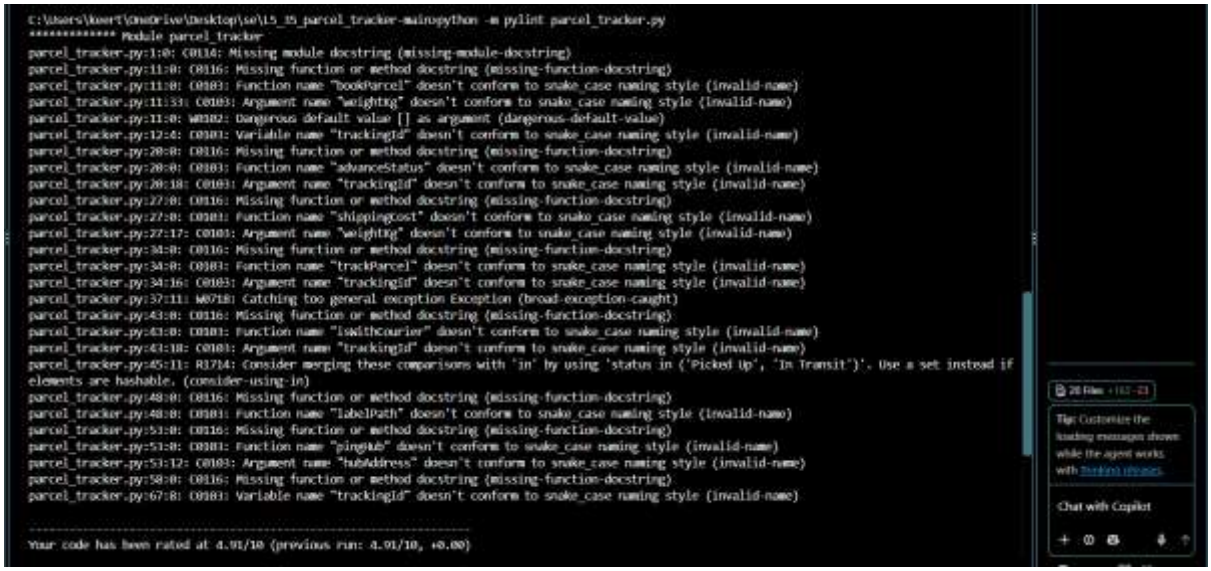
Lab 5: Static Code Analysis

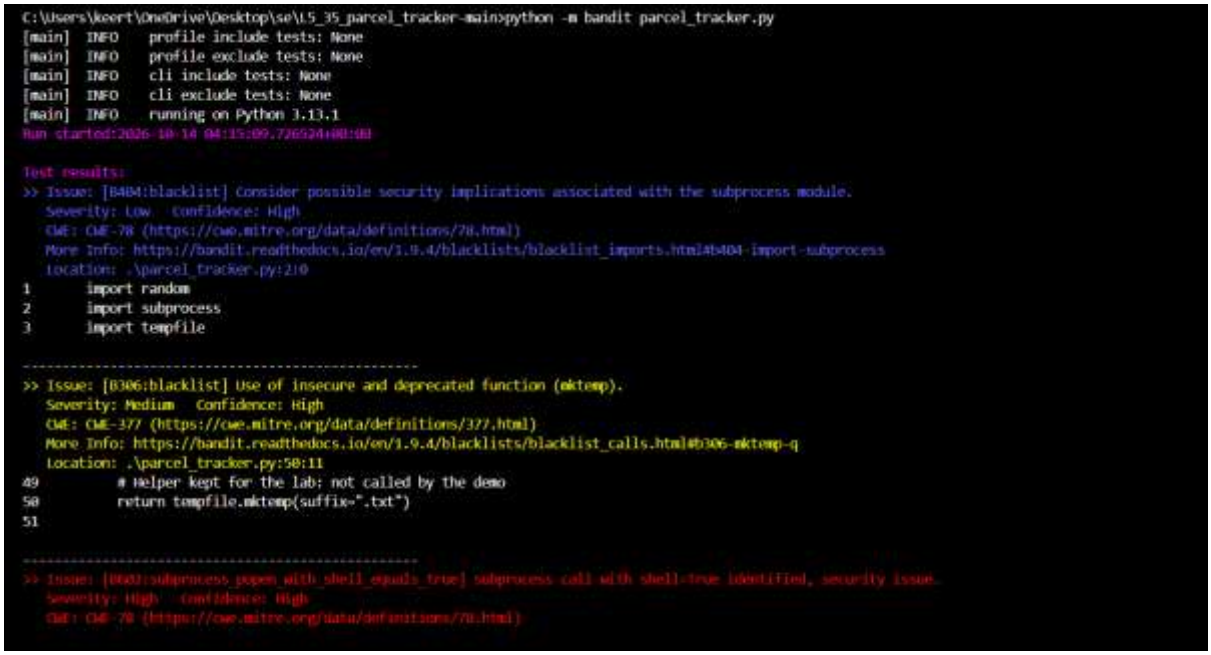
Project: Parcel Tracker

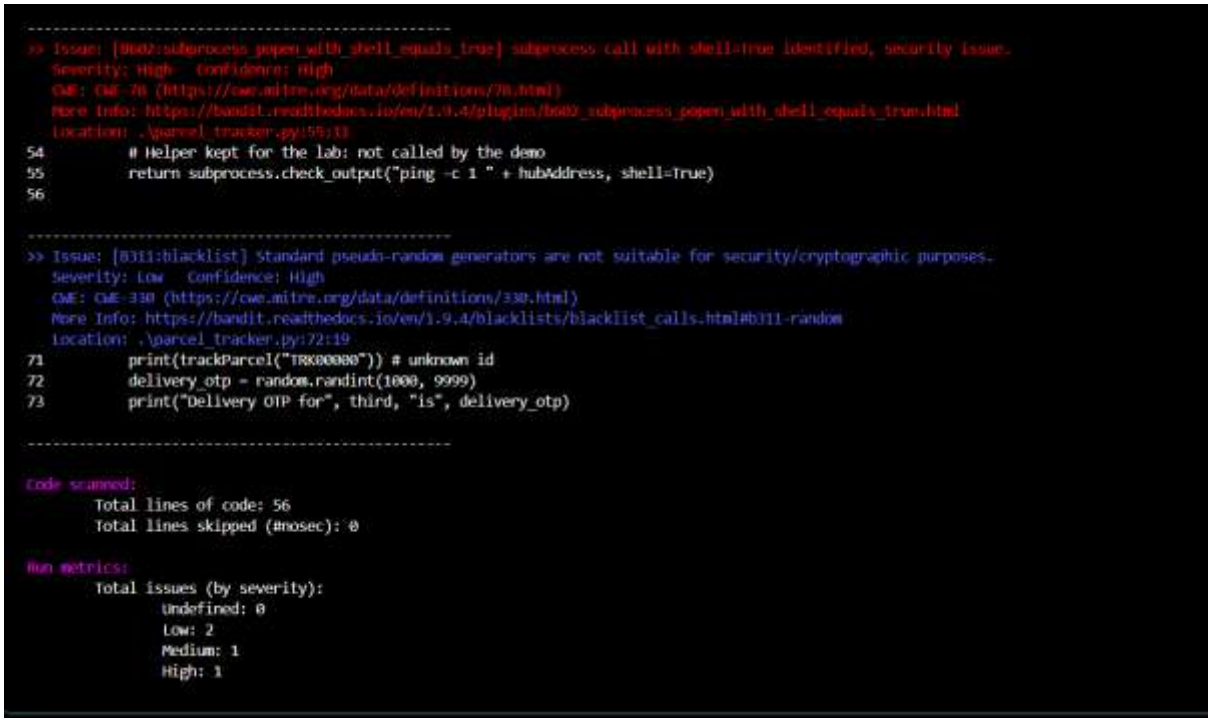
NAME:KEERTHI B PATIL

SRN:PES2UG24CS225

SECTION:D







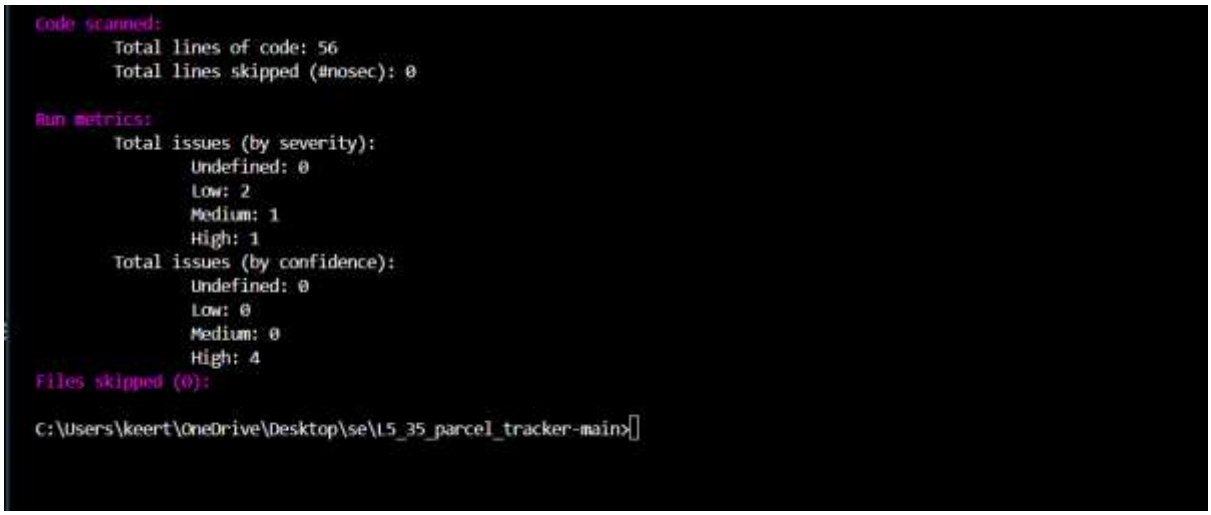
```
--------------------------------------------------
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True identified, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html
   Location: .\parcel_tracker.py:55:13
54          # Helper kept for the lab: not called by the demo
55          return subprocess.check_output("ping -c 1 " + hubAddress, shell=True)
56

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\parcel_tracker.py:72:19
71          print(trackParcel("TRK00000")) # unknown id
72          delivery_otp = random.randint(1000, 9999)
73          print("Delivery OTP for", third, "is", delivery_otp)

--------------------------------------------------

Code scanned:
        Total lines of code: 56
        Total lines skipped (#nosec): 0

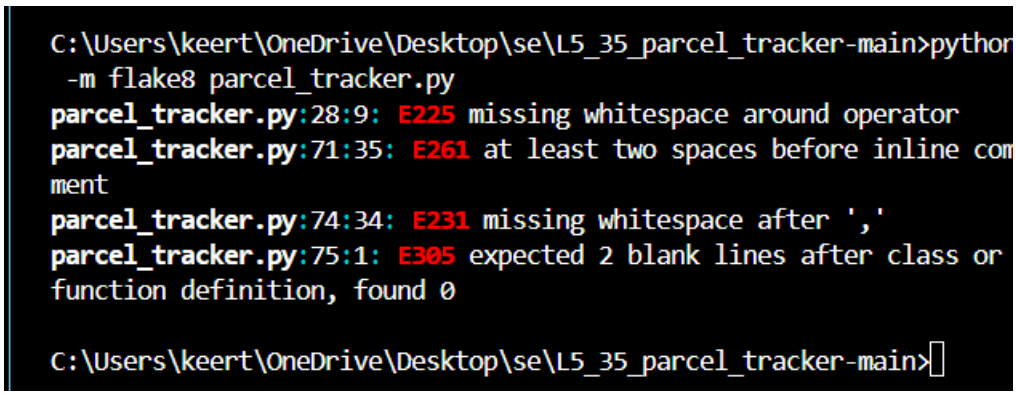
Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 1
```



```
Code scanned:
        Total lines of code: 56
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 4
Files skipped (0):

C:\Users\keert\OneDrive\Desktop\se\L5_35_parcel_tracker-main>
```



```
C:\Users\keert\OneDrive\Desktop\se\L5_35_parcel_tracker-main>python
 -m flake8 parcel_tracker.py
parcel_tracker.py:28:9: E225 missing whitespace around operator
parcel_tracker.py:71:35: E261 at least two spaces before inline com
ment
parcel_tracker.py:74:34: E231 missing whitespace after ','
parcel_tracker.py:75:1: E305 expected 2 blank lines after class or
function definition, found 0

C:\Users\keert\OneDrive\Desktop\se\L5_35_parcel_tracker-main>
```

Issue	Type	Line(s)	Description	Fix Approach
Broad exception handling	Bug	52–53	Catching a general exception can hide unexpected errors.	Replaced except Exception with except KeyError.
Unsafe subprocess execution	Security	63–67	Using shell=True can introduce command-injection risks.	Passed the command as a list of arguments and used shell=False.
Insecure temporary filename generation	Security	72	tempfile.mktemp() can create a race-condition risk.	Replaced it with tempfile.NamedTemporaryFile().
Insecure random number generation	Security	OTP section	The random module is not suitable for security-sensitive OTPs.	Replaced random.randint() with secrets.randbelow().
Inconsistent naming conventions	Code Quality	Throughout	Non-standard naming reduces code readability.	Used Python's snake_case naming convention.
Missing documentation strings	Code Quality	Throughout	Functions and the module lacked explanatory documentation.	Added module and function docstrings.
Code formatting violations	Style	Throughout	Spacing and blank-line issues reduced consistency.	Corrected formatting according to Python style conventions.